A Simulated ISO 27001:2022 Audit for a Nigerian FinTech startup

By Jennifer Zack

SCENARIO

Company Background

Company Name: PayLink Technologies Ltd
Location: Lagos, Nigeria
Industry: FinTech (mobile payments & SME lending)
Employees: 45
Customers: 120,000+ Nigerian users
Infrastructure:

- Hosted on Amazon Web Services (AWS)
- Uses Flutterwave and Paystack APIs
- Stores customer data (BVN-linked data, phone numbers, transaction history)
- Uses Microsoft 365 for email and documentation
- Developers push code via GitHub.

PayLink recently:

1. Experienced a phishing attack where a staff member's Microsoft 365 account was compromised.
2. Discovered that:
    - MFA was not enforced for all users.
    - There is no formal risk assessment documentation.
    - No incident response plan exists.
3. Is preparing for:
    - Investment funding from a UK VC firm.
    - Regulatory compliance review from CBN.
4. Wants ISO 27001 certification within 12 months.

Lead Auditor was hired to deliever ISO 27001 certification within 12 months.

Step one: Initiate the Audit Engagement & Establish Audit Foundations.

Process:

Conduct an Opening Meeting with Top Management

This meeting include:

- CEO
- CTO
- Head of Operations
- IT Lead
- Compliance Officer (if available)
- HR Manager

The purpose is to:

1. Establish management commitment
2. Understand the business context
3. Define the audit scope
4. Clarify expectations
5. Determine ISMS maturity level
6. Identify regulatory drivers (CBN, NDPR, etc.)

Since PayLink operates in Nigeria's financial ecosystem, regulatory compliance is critical. If they integrate with Central Bank of Nigeria guidelines or process BVN-linked data via APIs like Paystack, regulatory pressure becomes a major audit driver.

Reasoning:

ISO/IEC 27001:2022 Clause 5 makes it clear: An ISMS cannot function without:

- Defined leadership roles
- Approved information security policy
- Assignment of responsibilities
- Evidence of top management support

Since PayLink has never performed an ISO 27001 audit before, there is likely:

- No formal ISMS
- No documented risk assessment methodology
- No Statement of Applicability (SoA)
- No internal audit history
- No management review records

Step 2: Perform a Gap Assessment

After the opening meeting, the next immediate action is conducting a high-level gap analysis against ISO 27001:2022 clauses (4–10). This is to determine:

- Current maturity level
- Major structural deficiencies

- Readiness for Stage 1 audit

Process:

1. **Context of the Organization (Clause 4): This should contain the internal and external issues, interested, scope of isms and all organizational structures.**
    - Have you identified internal and external issues affecting information security?
    - Have you defined interested parties? (Customers, investors, regulators, staff)
    - Is the ISMS scope documented?

In a fintech like PayLink, interested parties may include:

- Nigerian customers
- Payment gateway partners
- Investors
- Regulators
- Cloud providers such as **Amazon Web Services**

If this is undocumented, it becomes a foundational gap.

2. **Leadership Commitment (Clause 5): This focuses on Management commitment, information security policies and roles and responsibilities of interested parties**

I would request:

- Information Security Policy
- Evidence of management approval
- Defined ISMS roles and responsibilities
- Appointment of an ISMS owner

If no policy exists, that becomes the first documented major gap.

3. **Planning (Clause 6): This focuses on Risk assessment, Information security objectives, Risk treatment**

Critical questions:

- Has a formal risk assessment been conducted?
- Is there a documented risk methodology?
- Is there a risk register?
- Has a risk treatment plan been defined?

For a fintech handling sensitive data (BVN, transaction records), absence of formal risk management is a major nonconformity.

4. **Support (Clause 7): This focuses on Resources, Competence & training Awareness**

- Is there a training program?
- Are staff security aware?

- Is documented information controlled?
- Is version control enforced?

If developers use personal laptops without endpoint controls, this becomes an early risk indicator.

5. **Operation (Clause 8): This focuses on Implementing risk treatment plans and Operate controls**

- Are operational controls defined?
- Is change management documented?
- Are cloud configurations reviewed?
- Are access privileges controlled?

For example:
If AWS admin credentials are shared, that's an immediate high-risk observation.

6. **Performance Evaluation (Clause 9): This focuses on** Monitoring & measurement, Internal audits and Management review

Since PayLink has never done an ISO audit before, likely missing:

- Internal audits
- Management reviews
- ISMS KPIs
- Monitoring and measurement records

7. **Improvement (Clause 10)**

- Is there an incident management process?
- Are corrective actions documented?
- Are security events tracked?

If the phishing attack mentioned earlier was not formally recorded and reviewed, that indicates immaturity in Clause 10 compliance.

Step 3: Report

After completing this initial engagement stage, I would produce:

Audit Initiation Report: Including

- Agreed scope
- Audit objectives and Audit criteria (ISO/IEC 27001:2022)
- Methodology
- Timeline
- Required documentation list

Preliminary Gap Assessment Report: This would be Classified into:

- Major gaps (structural absence)

- Minor gaps (partial implementation)
- Observations (improvement opportunities)

Step 4: **Detailed ISMS Documentation Review (Stage 1 Audit Phase)**

After the readiness assessment, the next formal stage is:

Conducting a Structured Stage 1 Audit – Documentation & ISMS Design Review

This stage determines whether PayLink's Information Security Management System (ISMS) is properly designed and documented in accordance with ISO/IEC 27001:2022 before moving into implementation verification.

Since PayLink has never performed an ISO 27001 audit before, this stage will likely uncover foundational deficiencies like:

- **Request and Review Mandatory Documents :** If these are missing, they are major nonconformities under Clauses 4 and 5.
- **Review Risk Management Framework (Clause 6):** If risks exist but no formal methodology exists, this becomes a major finding under Clause 6.1.
- **Review Statement of Applicability (SoA):** If PayLink excludes controls without justification, this is a structural weakness.
- **Evaluate Document Control (Clause 7.5):** Uncontrolled documentation compromises the integrity of the ISMS.
- **Confirm Internal Audit & Management Review Planning:** If there is no audit program defined, this indicates lack of compliance with Clause 9.

🧭 **Output of This Stage**

At the end of the Stage 1 Audit (Documentation Review), I would produce:

Stage 1 Audit Report

Including:

- ISMS maturity level
- Major nonconformities
- Minor nonconformities
- Observations
- Readiness determination for Stage 2

Possible conclusion:

"PayLink Technologies Ltd is not yet ready for Stage 2 certification audit due to absence of formal risk assessment records, incomplete Statement of Applicability, and lack of documented management review process."

Following the conclusion of the Stage 1 audit, PayLink Technologies Ltd was determined not to be ready for Stage 2 certification due to major nonconformities, specifically:

- Absence of a formal risk assessment methodology and risk register
- Incomplete Statement of Applicability (SoA)
- Lack of documented management review process

As a result, the next stage involves a structured **Corrective Action and ISMS Implementation Phase** aimed at addressing these deficiencies before progressing to Stage 2.

Key Actions in This Phase

1. Issuance of Nonconformity Report

A formal report is issued outlining identified major and minor nonconformities, including clause references, supporting evidence, and required corrective actions.

2. Development of Corrective Action Plan (CAP)

Top management must prepare and submit a Corrective Action Plan detailing root causes, corrective measures, responsible personnel, and implementation timelines.

3. Establishment of ISMS Foundations

PayLink must:

- Develop and document a formal risk assessment methodology
- Conduct a comprehensive risk assessment
- Create a risk treatment plan
- Complete a compliant Statement of Applicability (covering all Annex A controls)
- Establish and document a management review process

4. Implementation and Operationalization

The organization must implement selected controls and operate the ISMS for a reasonable period to generate objective evidence of effectiveness (e.g., logs, training records, access reviews, incident records).

5. Internal Audit and Management Review

Before progressing to Stage 2, PayLink must:

- Conduct a full internal audit of the ISMS
- Hold a documented management review meeting to evaluate ISMS performance and readiness

Internal Audit Phase

Internal Audit of the Information Security Management System (ISMS)

Organization: PayLink Technologies Ltd
Standard: ISO/IEC 27001:2022
Audit Type: First Internal ISMS Audit
Audit Criteria: ISO/IEC 27001:2022 Clauses 4–10 and Applicable Annex A Controls
Audit Scope: Information Security Management System covering cloud infrastructure, application development, corporate IT systems, and customer data processing operations at Lagos Headquarters.

1. Audit Objective

The objective of this internal audit was to:

- Determine conformity of the ISMS with ISO/IEC 27001:2022 requirements
- Verify implementation of documented policies and procedures
- Assess effectiveness of risk treatment measures
- Confirm closure of previously identified Stage 1 nonconformities
- Evaluate organizational readiness for Stage 2 certification audit

2. Audit Methodology

The internal audit was conducted using the following methods:

- Review of documented information
- Interviews with management and operational staff
- Inspection of technical configurations
- Sampling of records and logs
- Verification of risk treatment implementation

Departments interviewed included:

- Executive Management
- IT & Cloud Infrastructure
- Software Development
- Human Resources
- Operations

3. Audit Findings by ISO Clauses

Clause 4 – Context of the Organization

Findings:

- ISMS Scope document is formally defined and approved.
- Interested parties register has been documented (customers, investors, regulators, cloud providers).
- Internal and external issues affecting information security have been identified.

Conclusion:
Conformity achieved. No nonconformities observed.

Clause 5 – Leadership

Findings:

- Information Security Policy is documented and signed by CEO.
- ISMS roles and responsibilities are defined.
- ISMS Owner formally appointed.
- Evidence of top management communication on information security observed.

Conclusion:
Conformity achieved.

Clause 6 – Planning (Risk Management)

Findings:

- Documented risk assessment methodology established.
- Risk register completed and includes asset-based risk identification.
- Risk treatment plan developed and approved.
- Risk owners assigned.

Sample risks reviewed included:

- Cloud misconfiguration risks on infrastructure hosted on Amazon Web Services
- Phishing and account compromise risks
- Third-party API dependency risks

Observation:
Risk review frequency defined as annual; recommendation made to review quarterly due to fintech risk exposure.

Conclusion:
Conformity achieved with observation.

Clause 7 – Support

Findings:

- Security awareness training conducted; attendance records available.
- Competence requirements defined for IT and development teams.
- Document control procedure implemented using controlled repository.
- Access to ISMS documents restricted.

Minor Nonconformity Identified:

- No formal evaluation of training effectiveness (no post-training assessment evidence).

Clause 8 – Operation

Findings:

- Change management process documented and applied.
- Secure development practices implemented.
- Access control procedures defined.
- MFA enforced for administrative accounts.
- Backup process implemented and evidence of successful restoration test observed.

Sampling Performed:

- 12 out of 120 active user accounts (10%)
- 3 months of SIEM logs
- 5 change management records
- 2 backup restoration test records
- 3 supplier contracts
- 4 incident tickets

Conclusion:
Conformity achieved.

Clause 9 – Performance Evaluation

Findings:

- Internal audit program documented.
- This audit is the first cycle executed.
- ISMS performance indicators defined (incident count, patch compliance rate, access review completion rate).
- Monitoring records available.

Partial Nonconformity:

- Metrics are defined but trending analysis has not yet been performed.

Clause 10 – Improvement

Findings:

- Incident management procedure established.
- Phishing incident previously experienced has been documented and analyzed.
- Corrective actions implemented (MFA enforcement and email security hardening).
- Corrective action records maintained.

Conclusion:
Conformity achieved.

4. Annex A Control Sampling

Selected controls reviewed include:

- Access control management
- Logging and monitoring
- Cryptographic protection
- Supplier relationship security
- Backup controls
- Secure configuration management

The Statement of Applicability was reviewed and found to:

- List all 93 Annex A controls
- Provide justification for exclusions
- Reference risk treatment decisions

No unjustified exclusions observed.

5. Summary of Nonconformities

Type	Description	Clause
Minor	No documented training effectiveness evaluation	7.2
Minor	Performance metrics not trend-analyzed	9.1

No major nonconformities identified.

6. Overall Conclusion

The internal audit confirms that PayLink Technologies Ltd has:

- Established and implemented an ISMS aligned with ISO/IEC 27001:2022 requirements
- Closed previously identified major nonconformities
- Demonstrated operational evidence of risk management and control implementation

While minor improvements are required, no major nonconformities were identified.

Recommendation:
PayLink Technologies Ltd is considered ready to proceed to Stage 2 Certification Audit, subject to closure of minor nonconformities.

Stage 2 Certification Audit Report

Organization: PayLink Technologies Ltd
Standard: ISO/IEC 27001:2022
Audit Type: Stage 2 Certification Audit
Audit Scope: Information Security Management System (ISMS) covering cloud-hosted fintech application infrastructure, customer data processing, corporate IT operations, and software development lifecycle at Lagos Headquarters.
Audit Criteria: ISO/IEC 27001:2022 Clauses 4–10 and Applicable Annex A Controls

Objective of Stage 2 Audit

The objective of the Stage 2 Audit was to:

- Confirm implementation of the ISMS
- Verify operational effectiveness of controls
- Validate closure of Stage 1 nonconformities
- Assess conformity with ISO/IEC 27001:2022
- Determine eligibility for certification

Audit Methodology

The audit was conducted over five (5) days using:

- On-site interviews with staff
- Technical configuration inspection
- Live demonstration of controls
- Sampling of logs and records
- Review of incident and monitoring evidence
- Observation of operational processes

Departments assessed:

- Executive Management

- IT & Cloud Infrastructure
- Software Development
- Human Resources
- Customer Operations

Infrastructure reviewed included systems hosted on Amazon Web Services.

Detailed Audit Findings

Clause 4 – Context of the Organization

- ISMS scope properly defined and aligned with business operations.
- External issues include regulatory pressure and fintech threat landscape.
- Interested parties documented and monitored.

Result: Conformity confirmed.

Clause 5 – Leadership

- CEO demonstrated active involvement.
- Information Security Policy communicated to staff.
- Budget allocated for security tools and training.
- Management review minutes available.

Result: Effective leadership commitment demonstrated.

Clause 6 – Planning (Risk Management)

The audit verified:

- Documented risk assessment methodology.
- Updated risk register (last reviewed within 3 months).
- Risk treatment decisions aligned with business priorities.
- Evidence of risk acceptance approvals by management.

Sampled risks:

Risk ID	Control Selected	Annex A Reference	Treatment Status
R-01	MFA Enforcement	A.8.5	Implemented
R-02	Logging & Monitoring	A.8.15	Implemented
R-03	Supplier Agreements	A.5.19	Implemented

Risk scoring model applied consistently.

Result: Risk-based approach effectively implemented.

Clause 7 – Support

- Security awareness training conducted with post-training assessments.
- HR onboarding includes security briefing.

- Competence records maintained.
- Controlled document repository implemented.
- Access to ISMS documents restricted.

Result: Clause requirements satisfied.

Clause 8 – Operation

This was the most technically intensive part of the audit.

Access Control

- MFA enforced for privileged accounts.
- User access reviews conducted quarterly.
- No shared administrative accounts observed.

Logging & Monitoring

- Centralized logging enabled.
- Log review records available.
- Alerts configured for suspicious activity.

Backup & Recovery

- Daily backups automated.
- Restoration test successfully demonstrated during audit.

Secure Development

- Code review evidence sampled.
- Change management tickets reviewed.
- Separation of development and production environments confirmed.

Result: Operational effectiveness confirmed.

Clause 9 – Performance Evaluation

- Internal audit completed prior to Stage 2.
- ISMS KPIs tracked monthly.
- Trend analysis conducted.
- Management review performed with documented outcomes.

Result: Performance monitoring effective.

Clause 10 – Improvement

- Incident management process implemented.
- Previous phishing incident documented and corrective actions verified.
- Continuous improvement process active.

Result: Improvement cycle functioning.

Annex A Control Verification

A sample of implemented Annex A controls was tested for effectiveness, including:

- Access management controls
- Cryptographic controls
- Supplier security controls
- Business continuity arrangements
- Monitoring activities
- Asset inventory management

The Statement of Applicability was verified and found consistent with implemented controls and risk treatment decisions. No unjustified exclusions were identified.

Nonconformities Identified During Stage 2

No major nonconformities identified.

One minor observation:

- Improvement opportunity in automating log review documentation.

This does not affect certification eligibility.

Overall Audit Conclusion

Clause	Requirement	Conformity Status
Clause 4	Context of Organization	Conforming
Clause 5	Leadership	Conforming
Clause 6	Planning	Conforming
Clause 7	Support	Conforming
Clause 8	Operation	Conforming
Clause 9	Performance Evaluation	Conforming
Clause 10	Improvement	Conforming

PayLink Technologies Ltd has demonstrated that its Information Security Management System:

- Is fully implemented
- Is effectively maintained
- Meets the requirements of ISO/IEC 27001:2022
- Is suitable for certification

Certification Recommendation

It is recommended that: **PayLink Technologies Ltd be granted ISO/IEC 27001:2022 certification**, subject to routine surveillance audits.

ISO/IEC 27001:2022 CERTIFICATION AUDIT REPORT

Organization: PayLink Technologies Ltd

Location: Lagos, Nigeria

Audit Type: Full Certification Lifecycle (Simulated)

Lead Auditor: Jennifer Zack (ISO/IEC 27001:2022 Lead Auditor)

Report Date: February 28, 2026

Confidentiality Classification: Confidential – Portfolio Demonstration Only

1. Executive Summary

This report documents a full simulated ISO/IEC 27001:2022 certification lifecycle audit conducted for PayLink Technologies Ltd, a Nigerian FinTech organization. The audit engagement progressed from initial gap assessment to successful Stage 2 certification readiness.

At commencement, the organization lacked a structured ISMS framework, formal risk assessment methodology, and management review process. Through structured remediation and evidence-based verification, the ISMS matured to a defined, implemented, and operationally effective system.

2. Audit Program & Timeline

The audit lifecycle was executed as follows:

Stage 1 Audit | Duration: 3 Days | Key Activities: Documentation review, scope validation

Remediation Phase | Duration: 8 Weeks | Key Activities: Risk assessment, SoA development, control implementation

Internal Audit | Duration: 2 Days | Key Activities: Clause & control verification

Stage 2 Audit | Duration: 5 Days | Key Activities: Implementation & effectiveness testing

3. Audit Methodology

The audit was conducted in accordance with ISO 19011 auditing guidelines. Sampling methodology included review of 10% of active user accounts, 3 months of security logs, 5 change management tickets, and 2 backup restoration tests.

Audit techniques included interviews, technical inspection, document review, live demonstrations, and record sampling.

4. Risk Assessment Framework

The organization implemented a structured risk methodology including:

- Likelihood Scale (1–5)

- Impact Scale (1–5)

- Risk Score = Likelihood × Impact

- Risk acceptance threshold defined at ≤ 6

Risks exceeding threshold required treatment or documented management acceptance.

5. Stage 1 Audit Summary

Major nonconformities identified during Stage 1 included absence of documented risk methodology, incomplete Statement of Applicability, and lack of management review process.

Organization was deemed not ready for Stage 2 at that time.

6. Corrective Action & Remediation Phase

The organization implemented corrective actions including development of risk register, formal SoA completion, MFA enforcement, centralized logging, incident management procedures, and management review documentation.

7. Internal Audit Summary

Internal audit confirmed closure of major nonconformities. Minor findings included training effectiveness documentation and KPI trend analysis.

8. Stage 2 Certification Audit Summary

Stage 2 audit confirmed effective implementation of controls including MFA enforcement, quarterly access reviews, logging and monitoring, backup testing, and secure development practices.

No major nonconformities were identified during Stage 2.

9. ISMS Maturity Assessment

ISMS maturity progressed from Level 1 (Ad Hoc) to Level 3 (Defined and Implemented) based on governance, risk management, and control operationalization.

10. Value-Added Recommendations

- Implement automated SIEM solution for proactive monitoring.

- Introduce quarterly phishing simulations.

- Formalize third-party security scoring.

- Enhance KPI automation dashboards.

11. Lead Auditor Declaration

This simulated audit was conducted following ISO/IEC 17021 principles and ISO 19011 guidelines. Conclusions are based on objective evidence sampled during the audit period.

12. Conclusion & Certification Recommendation

Based on audit evidence reviewed, PayLink Technologies Ltd demonstrates conformity with ISO/IEC 27001:2022 requirements and is recommended for certification, subject to ongoing surveillance audits.